

뚫린 API를 찾는 도구는 많습니다. 얼마나 샀는지 세는 도구는 없습니다.

BOLA/BFLA 자동 탐지와 개인정보보호법 기반 노출 영향도 산정

실제 트래픽에서 API 목록을 복원하고, 남의 토큰으로 열리는 엔드포인트를 찾습니다.
거기서 새는 응답 필드를 개인정보보호법 분류로 환산해 어디부터 고칠지 순서를 매깁니다.

왜 지금인가

5 6주 동안 국내에서 터진 API 개인정보 유출 사고

시점	서비스	규모	공표된 원인
08-30	29CM	15만 9852건	주문조회 API
09-08	위버스	42만 2584건	결제 처리 API
09-08	강남언니	21만 9665건	상담 내역 조회 API
09-08	화해	미공개	비정상 접근 경로
09-15	레쥬메나인	미공개	서버 권한 검증 누락

145537, 145683, 145704, 145832

주문조회 API 뚫린 ‘29CM’... 이름·배송정보 등 15만9852건 유출

8월 27일 주문정보 조회 API 통해 외부 비정상 접근 포착
쇼핑몰 API 보안 강화 목소리 커져, 업계 전반 점검 필요성 대두

위버스, 결제 API 뚫려 42만건 정보 유출... “민감 정보는 무사”

외부 노출 API 노린 우회 공격으로 시스템 내부용 식별값 노출
민감정보 없어 실질적 크리덴셜 위협 가능성은 낮아

성형 사진부터 피부타입까지 털렸다... 강남언니·화해 고객 정보 유출

양사 모두 KISA 자진 신고 및 개별 통지... 강남언니는 공격자 특정해 수사 의뢰
최근 플랫폼 외부 연동 기능(API) 겨냥 공격 이어져

채용 플랫폼 레쥬메나인 개인정보 유출... 원인은 '서버 권한 검증 누락'

8월 19일 및 9월 7일 두 차례 외부 무단 접속·회원 정보 조회
사측 "비밀번호와 결제·계좌 정보는 안전" 취약점 보완 후 관계 기관 신고

문제

강남언니 운영사는 조치를 이렇게 공지했습니다. "인증 절차 강화 및 권한 검증 로직 재정비."
OWASP가 API1로 분류한 객체 수준 인가 실패입니다.

그런데 유출 항목을 보면 이야기가 달라집니다. 이름과 연락처만 나간 게 아닙니다. 상담 등록 사진, 시술 의사 식별값, 상담 동기까지 나갔습니다.

이 회사는 ISMS 인증을 갖고 있었습니다.

취약점은 API 하나였습니다.

피해 규모를 결정한 건 그 API가 무엇까지 내려줬는가였습니다.

지금 어느 도구도 이걸 세지 않습니다.

기존 도구가 멈추는 자리

ZAP, Burp 기본 스캐너	스캔 규칙은 요청과 응답의 패턴을 봅니다. 객체의 주인이 누구 인지는 패턴에 없습니다
------------------	---

Autorize, AuthMatrix	요청 재전송만 자동화합니다. 역할 정의와 최종 판정은 사람 몫입니다
----------------------	---------------------------------------

Akto, 42Crunch, Escape	뚫리는지까지는 답합니다. 얼마나 새는지는 답하지 않습니다
------------------------	---------------------------------

도구가 늘어도 이 항목은 줄지 않았습니다. OWASP Top 10 2021에서 인가 실패는 1위이고, 기여 데이터에서 31만 8487건으로 전 항목 중 가장 많습니다.

OWASP Top 10 2021, A01 Broken Access Control

만드는 것

1단계 엔드포인트 복원

mitmproxy로 실제 앱 트래픽을 받아 경로 변수를 일반화합니다. OpenAPI 스펙이 없어도 동작하는데, 실사고가 난 서비스들은 어차피 스펙을 공개하지 않습니다.

2단계 인가 취약점 탐지

계정 A의 리소스를 계정 B 토큰으로 요청합니다. 응답에 실린 신원이 토큰 주인과 다른 위반입니다. 그걸로 판정이 끝납니다.

신원이 안 실리는 엔드포인트에서만 두 응답을 비교합니다.

3단계 노출 영향도 산정 (본체)

새는 필드를 민감정보, 고유식별정보, 일반 개인정보로 나눠 가중합니다. 강남언니 유출 항목이 최고 등급으로 자동 분류되는지가

첫 검증 기준입니다. 순차 ID가 응답에 섞여 있으면 대량 수집 위험으로 가산합니다.

4단계 두 가지 출력

평시에는 수정 우선순위 리포트를 냅니다. 사고가 나면 같은 엔진이 유출 범위 산정서를 냅니다.

이미 확인한 것

OWASP crAPI에서 재현 완료

계정 B의 토큰으로 계정 A의 차량 위치를 조회했습니다. 서버가 막지 않았습니다.

```
status: 200
{
  carId: "8b5fc175-1918-4dff-aef2-22edc96b62da",
  vehicleLocation: { latitude: "31.284788", longitude: "-92.47111" },
  fullName: "Alice Tester",
  email: "alice@example.com"
}
```

엔드포인트 이름은 `/location` 입니다. 위치만 주면 되는데 소유자 이름과 이메일이 함께 나왔습니다. 화면에서는 보이지 않으니 개발자도 모릅니다. 강남언니에서 벌어진 일과 같은 구조입니다.

연구를 넘어서

규제가 수요를 만듭니다

개인정보보호법은 유출을 인지한 뒤 72시간 안에 유출 항목과 규모를 신고하도록 요구합니다. 이 산정을 자동화한 도구가 없습니다. 3단계 출력이 그대로 신고서 초안이 됩니다.

예산 라인이 비어 있습니다

API 보안 제품은 보안팀 예산입니다. 유출 범위 산정은 개인정보보호책임자 예산이고, 그 자리에는 경쟁 제품이 없습니다.

같이 하면 남는 것

역량 프록시로 API 트래픽을 다루고, 인가 로직을 직접 깨보고, 유출 항목을 법 분류로 옮기는 일까지 한 프로젝트 안에서 겪습니다. 벤치마크로 수치를 내본 경험이 함께 남습니다.

도메인 API 보안, 개인정보보호 컴플라이언스, 침해사고 대응이 맞물립니다. 어느 하나만 아는 지원자와 구별되는 지점입니다.

직무 모의해킹과 취약점 진단, 개인정보보호 컨설팅, 보안 솔루션 개발. 국내 채용에 실제로 열려 있는 직무들입니다.

웹과 API 취약점 진단은 국내 보안 채용에서 기본 소양으로 요구됩니다. 커널이나 저수준 지식 없이 들어갈 수 있어 진입 비용은 낮은 편입니다.